

POLÍTICA DE CONTROLO DE ACESSO

Gestão de identidades, autenticação, privilégios e palavras-passe

Organização	Entidade
Identificador	PCA-003
Versão	1.0 — Proposta para revisão e aprovação
Classificação	Uso interno
Proprietário	Função responsável definida pela Direcção
Aprovação	Direcção / órgão competente
Data de emissão	09 de Outubro de 2026
Revisão	Anual ou após alteração relevante

Nota de controlo: Documento de referência para validação interna. A aprovação deve ser precedida da confirmação das responsabilidades, dos requisitos legais e regulamentares aplicáveis, dos canais operacionais e dos controlos efectivamente implementados.

Histórico e controlo do documento

Versão	Data	Descrição	Responsável
1.0	09/10/2026	Emissão inicial para revisão	Função responsável

1. Objectivo e âmbito

Estabelecer regras para criar, alterar, rever e remover identidades e acessos a sistemas, aplicações, redes, dados e instalações lógicas. Aplica-se a colaboradores, administradores, terceiros e contas técnicas.

- O acesso deve ser concedido apenas mediante necessidade profissional, autorização e duração justificadas.
- As contas são individuais sempre que tecnicamente possível; contas partilhadas são excepcionais, controladas e rastreáveis.
- Os requisitos legais, regulamentares e contratuais aplicáveis prevalecem quando forem mais exigentes.

2. Princípios de controlo de acesso

- Menor privilégio: conceder apenas as permissões necessárias para executar tarefas autorizadas.
- Necessidade de conhecer: restringir a informação conforme a função e a classificação.
- Segregação de funções: evitar que uma única pessoa controle todas as etapas críticas de uma operação.
- Responsabilização: cada acção deve poder ser associada a uma identidade ou processo autorizado.
- Acesso temporário: privilégios elevados e acessos de terceiros devem ter prazo e ser removidos quando deixam de ser necessários.

3. Ciclo de vida das identidades

3.1. Criação e alteração

A criação de contas deve resultar de pedido formal, validação do responsável e confirmação da identidade. A função, o perfil de acesso, o proprietário do recurso e a data de validade, quando aplicável, devem ser registados. Mudanças de função devem desencadear revisão dos acessos anteriores.

3.2. Saída ou suspensão

A revogação deve ser coordenada com Recursos Humanos e o responsável do sistema. Em saídas involuntárias ou risco de segurança, os acessos devem ser suspensos no momento definido pelo processo de saída e pelas instruções autorizadas. Devem ser revogados sessões activas, tokens, chaves, VPN e acessos de terceiros, conforme aplicável.

3.3. Revisões periódicas

Os proprietários dos sistemas devem rever os acessos numa periodicidade baseada no risco, com maior frequência para contas privilegiadas, sistemas críticos e terceiros. A revisão deve confirmar a necessidade, detectar privilégios excessivos e documentar decisões e correcções.

4. Autenticação e palavras-passe

- A autenticação multifactor (MFA) deve ser obrigatória para acesso remoto, contas privilegiadas, correio electrónico e sistemas críticos sempre que suportada; qualquer excepção deve ser formalmente aprovada e compensada.
- As palavras-passe devem ser únicas, suficientemente longas e não reutilizadas entre serviços corporativos e pessoais. Recomenda-se uma frase-passe longa e difícil de adivinhar.
- É proibido partilhar palavras-passe, códigos de utilização única, chaves privadas ou aprovações MFA.
- As palavras-passe devem ser alteradas imediatamente quando houver suspeita de exposição; alterações periódicas obrigatórias devem seguir a avaliação de risco e os requisitos aplicáveis, evitando mudanças arbitrarias que incentivem padrões previsíveis.
- As credenciais devem ser armazenadas em mecanismos aprovados; é proibido guardá-las em texto simples, scripts sem protecção, documentos abertos ou repositórios de código.
- Devem ser aplicados limites e monitorização de tentativas de autenticação, bloqueio ou atraso progressivo e alertas para comportamentos anómalos.

5. Contas privilegiadas e técnicas

- Administradores devem utilizar contas separadas para tarefas correntes e tarefas privilegiadas.
- Privilégios devem ser atribuídos por tempo e finalidade, com registo das actividades relevantes.
- Contas de serviço devem ter proprietário, finalidade, permissões mínimas, credenciais protegidas e revisão periódica.
- Credenciais predefinidas devem ser removidas ou alteradas antes de colocar sistemas em produção.
- Acesso de emergência deve ser limitado, monitorizado, registado e revisto após utilização.

6. Acesso remoto, terceiros e dispositivos

O acesso remoto deve usar canais aprovados, encriptação adequada e MFA quando disponível. Os dispositivos utilizados devem cumprir requisitos de segurança. Terceiros devem ter contas identificáveis, âmbito restrito, prazo definido e acompanhamento do patrocinador interno.

- Não permitir acesso directo a sistemas críticos a partir de redes não confiáveis sem controlos aprovados.
- Revogar acessos de fornecedores no fim do contrato, da intervenção ou da necessidade.
- Não utilizar contas pessoais ou de terceiros para contornar processos de autorização.

7. Registos e tratamento de violações

Os eventos de autenticação, alterações de privilégios, criação e remoção de contas e acessos administrativos devem ser registados e protegidos. Suspeitas de roubo de credenciais, MFA fatigue, abuso de privilégios ou acesso indevido devem ser comunicadas imediatamente e tratadas segundo o processo de resposta a incidentes.

Responsabilidades principais

Papel	Responsabilidades
Direcção competente	Aprovar a política, o apetite ao risco e as excepções de maior impacto.
Segurança da Informação	Definir requisitos, acompanhar riscos, analisar desvios e coordenar revisões de segurança.
TI / administradores	Implementar acessos, autenticação, registos, revogação e controlos técnicos.
Responsáveis de negócio	Autorizar acessos necessários e confirmar periodicamente a sua adequação.
Recursos Humanos / gestores de contrato	Comunicar admissões, mudanças, saídas e fim de contratos.
Utilizadores	Proteger credenciais e reportar suspeitas de comprometimento.

Monitorização e evidências

A função responsável deve definir a periodicidade, fonte, responsável e destinatário de reporte dos indicadores abaixo, mantendo evidências proporcionais ao risco e aos requisitos aplicáveis.

- Percentagem de contas privilegiadas com MFA.
- Percentagem de revisões de acesso concluídas no prazo.
- Número de contas órfãs, inactivas ou sem proprietário.
- Tempo entre comunicação de saída e revogação efectiva.
- Número de excepções vencidas e acessos de terceiros sem prazo.

Excepções, incumprimento e revisão

Qualquer excepção deve ser solicitada por escrito, justificada, avaliada quanto ao risco, aprovada pela autoridade competente, limitada no tempo e acompanhada de medidas compensatórias. Não pode contrariar obrigações legais ou regulamentares. O incumprimento pode resultar em medidas correctivas, restrição de acessos ou consequências disciplinares e contratuais, conduzidas pelas áreas competentes. O documento deve ser revisto pelo menos anualmente e após alterações relevantes, incidentes significativos ou mudanças legais.

Aprovação formal

Etapa	Responsável / nome	Assinatura e data
Elaboração	A preencher	A preencher
Revisão técnica / jurídica	A preencher	A preencher
Aprovação — Direcção competente	A preencher	A preencher

Entrada em vigor: após aprovação formal e divulgação aos destinatários abrangidos.